SECURITY · PENETRATION TEST RESPONSE

Response to the penetration test

Our response to STA's web penetration test of the TOURISE 2027 registration platform (report 72, version 1.0, 15 September 2026).

To: **Saudi Tourism Authority (STA)** · Date: **19 October 2026** · Classification: **CONFIDENTIAL**

1. Summary

STA's penetration test assessed `register.tourise.com` and the API behind it from the internet on 14 and 15 September 2026 and reported five findings, all rated Medium. We verified each one against the application's source code and the production configuration.

All five findings are accepted. Four are fixed. For the fifth (M-005) we have reduced the risk and propose that the remainder be accepted, for the reason given in section 6.

ID	Finding	Severity	Our position	Status
M-001-072	Outdated Next.js version	MEDIUM	Accepted	FIXED
M-002-072	Improper error handling	MEDIUM	Accepted	FIXED
M-003-072	Information disclosure (database columns)	MEDIUM	Accepted, wider than reported	FIXED
M-004-072	OTP bypass	MEDIUM	Partially accepted, a related weakness fixed	FIXED
M-005-072	User enumeration	MEDIUM	Accepted, risk reduced	PARTIAL

2. M-001-072 · Outdated Next.js version · ACCEPTED

Both Next.js applications, the public site and the administration panel, ran version 15.5.19.

Done. Both now run **Next.js 15.5.28**, the latest 15.x release. It fixes the eight CVEs in the report (CVE-2026-64641 to CVE-2026-64649) and the later August and September 2026 Next.js security releases.

3. M-002-072 · Improper error handling · ACCEPTED

Cause. The production API ran with debug mode on, so errors returned stack traces and file paths, and the two database errors in the report also returned connection details.

Done.

- Debug mode is off on production. Errors return a status and a short message only.
- Client errors keep their correct status (401, 403, 405, 422); any unexpected error returns only "Internal server error." Automated tests check this with debug mode off.
- The database error behind the evidence can no longer occur (M-003). Validation of one remaining registration field is scheduled.
- The framework's error page tool is development-only; on production its endpoint answers `404`.

4. M-003-072 · Information disclosure (database columns) · ACCEPTED

Cause. The email check took the database column name from the request, so unknown names exposed the schema and other columns could be queried.

Done. The endpoint checks email only, fixed on the server. Any other type is refused with `422`, and it never returns a guest record.

5. M-004-072 · OTP bypass · PARTIALLY ACCEPTED

Our analysis. Changing the response in the browser only moves the form to its next step. The server checks the code again and refuses the registration without a valid one.

Fixed. The server accepted any valid code without matching it to the email being registered. A code is now accepted only with the address it was sent to, and is deleted once used. Codes are eight random letters and digits and cannot be reused; an expiry window is scheduled.

6. M-005-072 · User enumeration · ACCEPTED, RISK REDUCED

Confirmed. The registration form's email lookup, and a second one on the request-an-invitation form, said whether an address was already registered.

Decision. We keep the "already registered" message on purpose: guests are invited, and someone registering twice needs to know why.

Done. Both lookups now require a valid Google reCAPTCHA token on every request, and the check also refuses low risk scores. Partner integrations use a separate endpoint behind an API key and approved server addresses.

Residual risk. A single address can still be checked by hand, as a returning guest does; checking addresses in bulk needs a fresh reCAPTCHA token for each one. **We propose that STA accepts this residual risk.** If STA prefers a generic message, we will implement it and inform returning guests by email instead.